

Identity, Trust and Authorization Architecture v2

High-Level Logical Architecture for Android Applications, Body-Worn Cameras, Smart Goggles and Evidentiary Data

Yaseen Ahmed
yaseen.ahmed@aeriaone.com

Table of Contents

Table of Contents.....	0
1. Executive Summary.....	3
1.1. Key decisions.....	3
1.2. Scope	3
1.3. Out of Scope.....	3
2. Architecture Principles.....	4
3. First-Class Identity and Trust Objects.....	4
3.1. Non-equivalence rules.....	5
3.2. Illustrative dependency graph.....	5
4. High-Level Logical Architecture.....	5
5. Logical Components and Responsibilities.....	6
6. Relationship / Binding Registry.....	7
6.1. Binding states.....	7
6.2. Minimum binding fields.....	7
7. User Authentication and Operational Session.....	8
7.1. Routine user login / unlock.....	8
7.2. Session token as trust-graph representation.....	8
7.3. Session lifecycle.....	8
8. Device, Peripheral and Application Trust.....	9
8.1. Authenticated peripheral pairing.....	9
8.2. Application release and instance controls.....	9
9. Authorization Model.....	10
9.1. Illustrative decisions.....	10
9.2. Enforcement points.....	10
10. Evidence and Data Trust Layer.....	11
10.1. Evidence lifecycle.....	11
10.2. Historical validation.....	11
11. PKI, Keys, Release Trust and Time.....	12
11.1. Certificate/key lifecycle.....	12
11.2. Revocation checking.....	12
11.3. CA rotation.....	12
12. Offline Operations and Reconciliation.....	13
12.1. Reconciliation sequence.....	13
12.2. Decisions to finalize.....	13

13. Revocation, Compromise and Recovery.....	14
13.1. Response pattern.....	14
14. Audit, Monitoring and Administrative Control.....	15
14.1. Audit qualities.....	15
14.2. Separation of duties.....	15
15. High-Level Security Requirements.....	16
16. Implementation Roadmap and Ownership.....	17
16.1. Responsibility boundary.....	17
16.2. Required next design artifacts.....	17
Appendix A. Workflow Coverage Catalogue.....	18
A.1. Tenant & Governance.....	18
A.2. User Identity.....	18
A.3. Device Trust.....	18
A.4. Application Trust.....	19
A.5. Authentication & Session.....	19
A.6. Pairing & Binding.....	19
A.7. Evidence Trust.....	19
A.8. Offline & Resilience.....	20
A.9. PKI & Key Lifecycle.....	20
A.10. Platform Operations.....	20
A.11. Incident & Revocation.....	20
A.12. Audit & Monitoring.....	20
Appendix B. Acceptance Checklist.....	21

1. Executive Summary

AeriaOne IAM is not a conventional username-and-password service. It is a multi-identity trust and authorization platform governing QPD users, Android/BYOD devices, body-worn cameras, smart goggles, installed APK instances, approved APK releases, backend workloads, operational sessions and evidence objects.

The architectural center is the Relationship / Binding Registry. It records which QPD user may operate which enrolled Android device, which installed APK instance originates from which trusted release, which peripherals are temporarily bound to the operational session, and which entitlements apply. The Policy and Authorization Engine evaluates this trust graph before issuing a short-lived session token.

1.1. Key decisions

- Routine sign-in does not ask the officer to type the username again. The APK already knows `cmendez.aeriaone.com`; the PIN/passcode authorizes use of the protected user private key.
- User, Android, peripheral, APK release, APK instance and workload identities remain separate and independently revocable.
- Body cameras and goggles never become `cmendez.aeriaone.com`; they operate on behalf of the user through a time-limited binding.
- Evidence inherits verifiable provenance: tenant, operational user, controller/capture devices, APK, session, timestamp, hashes, signatures, encryption and custody.
- Offline operation is bounded by cached signed authorization, expiry rules, local integrity and mandatory reconciliation.

1.2. Scope

- Human, tenant, device, peripheral, application, release, workload, session and data identities
- Enrollment, binding, authentication, authorization, revocation and audit
- Evidence provenance, signing, encryption, ingest and custody integration
- Online and controlled offline operating modes

1.3. Out of Scope

- Biometric authentication for officers
- User-facing OTP, dongle or formal MFA requirement
- Detailed physical network topology or product UI design
- Country-specific evidentiary admissibility opinion

2. Architecture Principles

1. **Identity is not authorization:** Certificates prove possession of keys; current access also requires active records, bindings, trusted software, compliant posture and entitlement.
2. **Separate every trust subject:** User, handset, peripheral, APK instance, release, workload, session and evidence have distinct identifiers and lifecycles.
3. **Make relationships explicit:** User-device, device-APK, user-APK, user-peripheral and tenant-policy relationships reside in a central trust graph.
4. **Use short-lived authorization:** Tokens represent a recently validated trust graph; they are not permanent identities.
5. **Revocation is granular:** AeriaOne can independently disable a user, device, certificate, APK instance/release, peripheral, entitlement, session or tenant.
6. **Preserve historical truth:** Later revocation blocks new activity without erasing valid signing-time evidence.
7. **Assume intermittent connectivity:** Offline functions use bounded cached trust and reconcile when connectivity returns.
8. **Audit every material decision:** Authentication, binding, policy, revocation, evidence and privileged events are tamper-evident.

Everything authenticates, the device is authenticated, user is authenticated with device and back end directory, videos are authenticated by the user and so on...

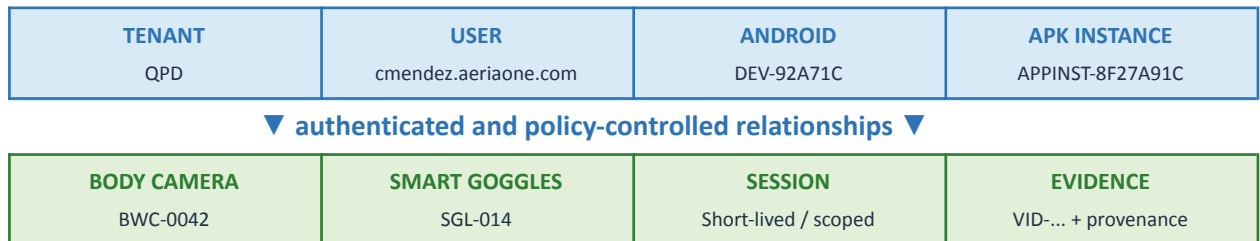
3. First-Class Identity and Trust Objects

OBJECT	QPD EXAMPLE	AUTHORITATIVE FUNCTION
Tenant identity	QPD	Security, policy, data and delegated administration boundary
User identity	cmendez.aeriaone.com + UUID	Human account, role, status and entitlements
User credential	User certificate + protected key	Proof of possession for enrolled user identity
Device identity	DEV-92A71C / BWC-0042 / SGL-014	Independent identity/status of each physical device
Device credential	Unique device certificate + key	Cryptographic proof of device identity
APK release identity	APK v3.4.2 + signer + hash	Approved software artifact and signing lineage
APK instance identity	APPINST-8F27A91C	Activated installation bound to user/device/tenant
Workload identity	svc-evidence-upload	Least-privilege backend service identity
Operational session	Short-lived token + jti	Temporary outcome of validated trust and policy
Evidence identity	VID-20260902-88372	Provenance, integrity, encryption and custody state

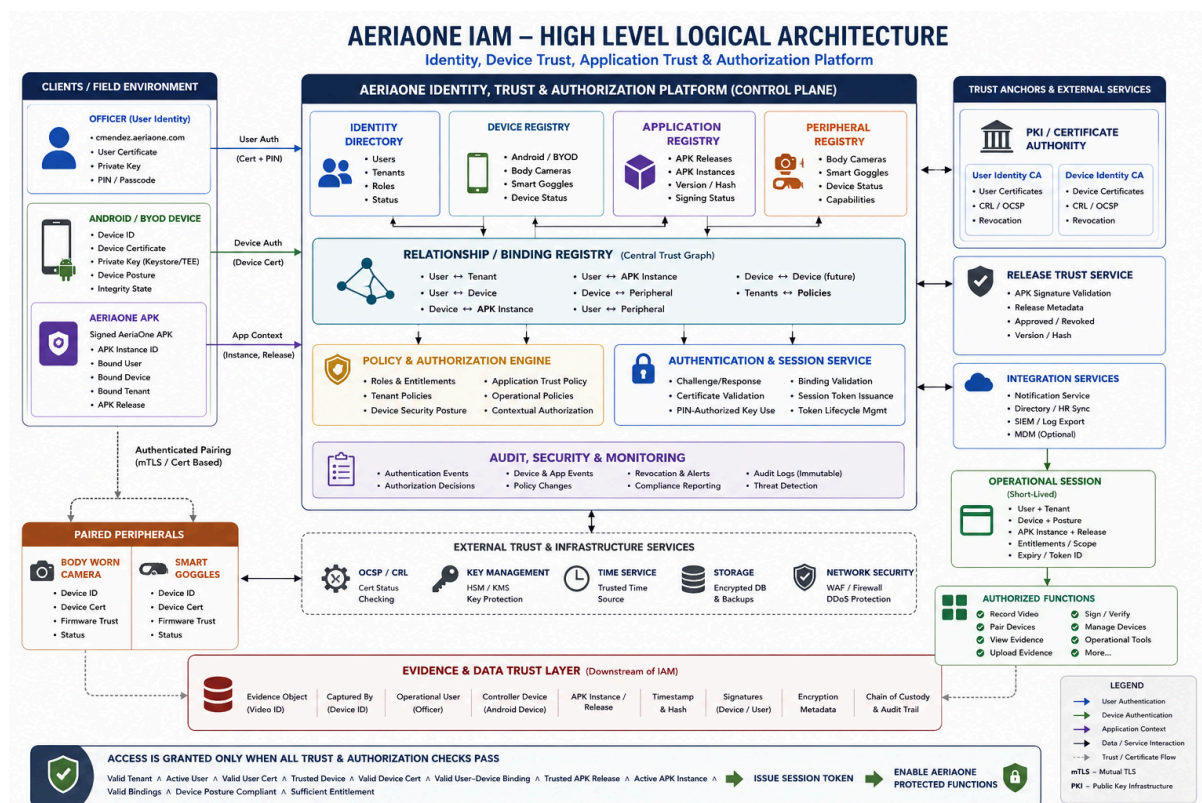
3.1. Non-equivalence rules

- User certificate is not the device certificate.
- APK production signature is not the APK instance identity.
- An APK instance is not trusted merely because its release was once approved.
- A peripheral binding does not copy the officer identity to the peripheral.
- A session token is a temporary authorization result, not an identity.
- A valid certificate is not equivalent to authorized access.

3.2. Illustrative dependency graph



4. High-Level Logical Architecture



5. Logical Components and Responsibilities

1. **Identity Directory:** Users, tenants, roles, status and delegated QPD administration.
9. **Device Registry:** Android/BYOD, body cameras, goggles, certificates, posture, capabilities and state.
10. **Application Registry:** APK releases, signing lineage, version/hash, approval state and APK instances.
11. **Peripheral Registry:** Body-camera and goggles inventory, certificate, firmware trust, status and capabilities.
12. **Relationship / Binding Registry:** Authoritative graph of user-tenant, user-device, device-APK, user-APK, device/user-peripheral and tenant-policy relationships.
13. **Policy & Authorization Engine:** RBAC, entitlements, tenant policy, device posture, application trust, operational context and resource policy.
14. **Authentication & Session Service:** Fresh challenges, signature/certificate/binding validation, token issue, renewal and termination.
15. **PKI / Certificate Authority:** Separate user/device profiles, proof-of-possession, status, renewal and revocation.
16. **Release Trust Service:** APK signature, signer, hash/version, approval, rollback prevention and kill decisions.
17. **Audit, Security & Monitoring:** Authentication, authorization, binding, device/app, revocation, evidence and alerts.
18. **Integration Services:** QPD directory/HR sync, notifications, SIEM export and optional MDM.
19. **External Trust Services:** HSM/KMS, trusted time, storage/backup, revocation distribution and network security.
20. **Evidence & Data Trust Layer:** Evidence identity, provenance, signatures, hashes, encryption, acceptance and custody.

6.Relationship / Binding Registry

The Binding Registry is the architectural heart of AeriaOne IAM. It prevents trust from being inferred from scattered records or from possession of one certificate. Each binding is explicit, versioned, time-bounded where appropriate, auditable and independently revocable.

RELATIONSHIP	EXAMPLE	POLICY PURPOSE
User ↔ Tenant	cmendez ↔ QPD	Organizational membership and policy boundary
User ↔ Android device	cmendez ↔ DEV-92A71C	Officer assignment to handset
Device ↔ APK instance	DEV-... ↔ APPINST-...	Installation registered on device
APK instance ↔ Release	APPINST-... ↔ APK v3.4.2	Link to approved signed artifact
User ↔ APK instance	cmendez ↔ APPINST-...	Activation for enrolled user
Device ↔ Peripheral	DEV-... ↔ BWC-0042	Mutually authenticated pairing
User ↔ Peripheral	cmendez ↔ BWC-0042	Temporary operational attribution
Tenant ↔ Policy	QPD ↔ QPD policy	Tenant rules and entitlements

6.1. Binding states

REQUESTED	ACTIVE	SUSPENDED	TERMINATED
Awaiting validation	Authorized relationship	Temporarily unusable	Closed; retained for audit

6.2. Minimum binding fields

- Binding ID/type and immutable subject/object IDs
- Tenant and policy version
- Creator, approver and authoritative source
- Activation, expiry and termination time
- Status and revocation reason
- Related session, shift, case or assignment
- Audit references and integrity protection

7. User Authentication and Operational Session

7.1. Routine user login / unlock

1. **Retrieve enrolled identity:** The APK displays cmendez.aeriaone.com, QPD and the bound device; the officer does not re-enter the username.
2. **Challenge PIN/passcode:** The officer enters the local secret under rate limiting and lockout policy.
3. **Authorize key use:** Successful local verification permits the protected user key to sign; PIN/private key never leave the device.
4. **Perform challenge-response:** The backend issues a fresh context-bound nonce; the user key signs it to prove possession and prevent replay.
5. **Submit trust context:** Send signed challenge plus tenant, device/posture, APK instance/release and binding references.
6. **Validate and authorize:** Validate certificates/revocation, release, instance, bindings, tenant, posture and entitlement.
7. **Issue session:** Issue a short-lived token scoped to the validated graph/functions only after every mandatory check passes.

7.2. Session token as trust-graph representation

CLAIM	ILLUSTRATIVE VALUE	PURPOSE
sub	cmendez.aeriaone.com / UUID	Operational user
tenant	QPD	Policy/data boundary
device	DEV-92A71C	Authenticated controller
appinst	APPINST-8F27A91C	Activated installation
release	3.4.2 + release ID	Approved software identity
bindings	IDs / versions	Validated relationships
roles/permissions	PoliceOfficer; video.record/upload	Authorized functions
iat/exp/jti	Issue, expiry, token ID	Lifetime/replay control

7.3. Session lifecycle

UNLOCK PIN-authorized key	AUTHENTICATE Fresh signed challenge	AUTHORIZE Evaluate trust graph	ISSUE Short-lived; re-evaluate to refresh
-------------------------------------	---	--	---

8. Device, Peripheral and Application Trust

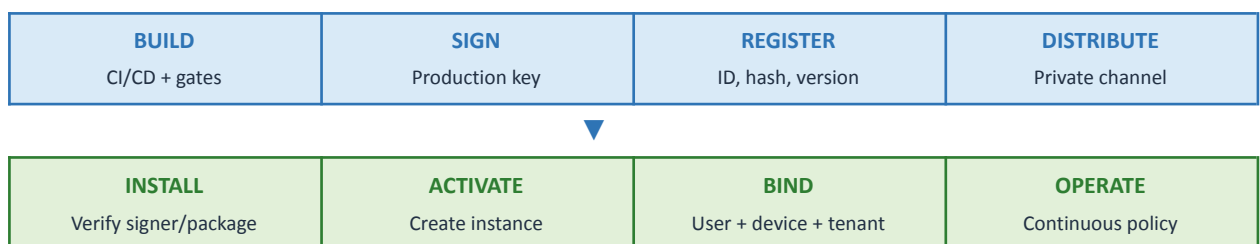
Android devices, body-worn cameras and smart goggles each require a unique ID/key/certificate, registry record, firmware/security state and lifecycle status. Ownership and assignment are bindings—not permanent identity attributes.

SUBJECT	MUST PROVE	MUST NOT IMPLY
Android/BYOD	Key possession, certificate, enrollment, posture and binding	That the current human is cmendez
Body-worn camera	BWC identity, certificate, firmware and active binding	That the camera itself is the officer
Smart goggles	Goggles identity, certificate, firmware and binding	That proximity equals authorization
APK release	AeriaOne signer, hash, version and approval	That every installed instance is active
APK instance	Instance ID bound to user/device/tenant/release	That copying the APK preserves access

8.1. Authenticated peripheral pairing

1. **Discover and identify:** Read peripheral ID, certificate and capabilities.
21. **Mutually authenticate:** Both devices prove keys and validate trust/status.
22. **Verify policy:** Check tenant, model/firmware, state and pairing entitlement.
23. **Confirm asset:** Officer confirms intended physical asset/code where supported.
24. **Create bindings:** Record device-peripheral and time-limited user-peripheral relationships.
25. **Establish channel:** Derive authenticated encrypted control/transfer session.
26. **Unbind:** Terminate at shift end, logout, timeout, reassignment or revocation.

8.2. Application release and instance controls



A copied APK may install where Android permits, but cannot activate or reach production without enrolled device, active instance, approved release and valid user/device/tenant bindings.

9. Authorization Model

Authentication proves possession of registered keys. Authorization decides whether the complete context may perform the requested operation on a resource. The engine combines role-based, attribute-based and contextual policy.

POLICY INPUT	EXAMPLES
Subject	User UUID, role, function, status, tenant and entitlements
Device	ID, type, certificate status, posture, firmware, assignment and risk
Application	Package, signer, release/version/hash, instance and activation state
Relationships	User-device, device-instance, user-instance and peripheral/session bindings
Resource	Evidence ID, owner, tenant, case, classification, retention and custody
Action	Record, pair, upload, view, export, administer, revoke or delete
Context	Time, connectivity, shift/mission, lawful location, network and risk
Policy state	Tenant policy, revocation, minimum release and emergency state

9.1. Illustrative decisions

REQUEST	OUTCOME	RATIONALE
Record video on active BWC	Allow	Active user/session, pairing, entitlement and trusted firmware
Copied APK on emulator	Deny	No enrolled device, active instance or binding
Upload from revoked handset	Deny/quarantine	Device/certificate revoked even if user active
View another officer evidence	Deny unless entitled	Ownership/case policy not satisfied
Offline recording within entitlement	Allow with limits	Cached signed policy and local controls valid
Export evidence	Controlled workflow	Custody, purpose, approval and export policy required

9.2. Enforcement points

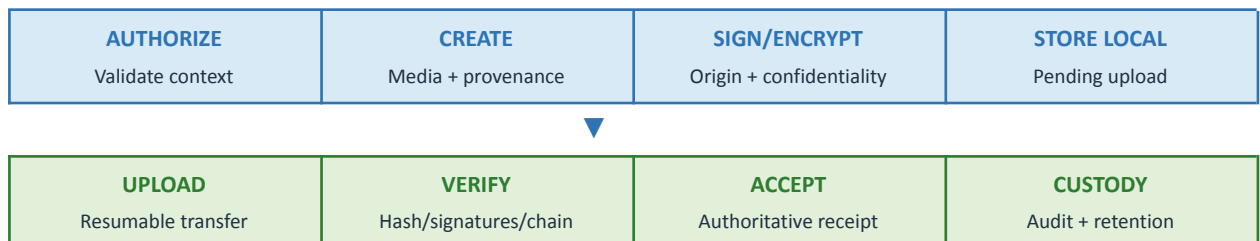
Policy is enforced at the Android APK and protected-key interface, peripheral firmware and pairing service, API gateway and session service, upload/ingest service, evidence access/export/retention services, administrative portals and workload-to-workload calls.

10. Evidence and Data Trust Layer

Evidence is downstream of IAM but linked to the trust graph that authorized creation. The capture device signs as itself; user attribution comes through the validated session and binding—not device impersonation of the officer.

PROVENANCE ELEMENT	EXAMPLE / FUNCTION
Evidence object ID	VID-20260902-88372
Tenant	QPD boundary
Operational user	cmendez.aeriaone.com + UUID
Capture device	BWC-0042/SGL-014 + certificate reference
Controller device	DEV-92A71C
Application	APPINST... + approved release/version/hash
Operational session	Session, bindings, entitlements and policy version
Trusted time	Capture sequence and source/quality
Integrity	Chunk/object hashes, sequence and signatures
Confidentiality	Encryption context/key reference—not raw key
Custody	Create, queue, transfer, accept, view, export, archive/dispose

10.1. Evidence lifecycle



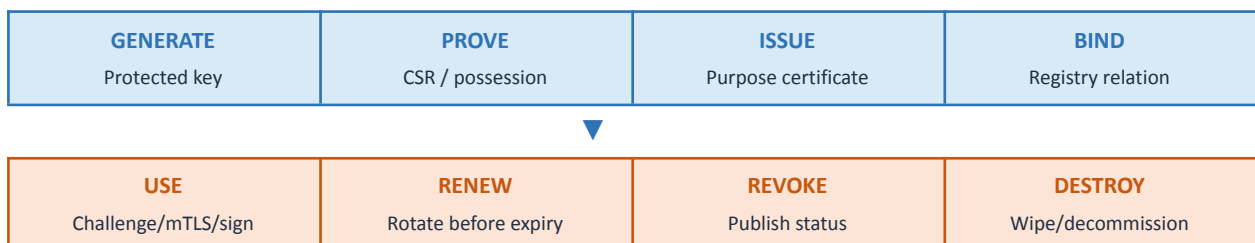
10.2. Historical validation

Later revocation blocks new use without erasing earlier valid attribution. AeriaOne retains signing-time certificate status evidence, binding/policy references and trusted timestamps.

11. PKI, Keys, Release Trust and Time

TRUST DOMAIN	PURPOSE	SEPARATION REQUIREMENT
User Identity CA	User proof-of-possession certificate	Separate profile/policy from device credentials
Device Identity CA	Android/BWC/goggles authentication	Unique key per device; non-exportable where supported
Workload identity	Service authentication/mTLS	Short-lived/automated rotation; least privilege
APK signing	Authenticity and release lineage	HSM/offline production signing; never evidence key
Evidence signing	Integrity/origin of media/provenance	Distinct from transport and APK signing
Encryption keys	Confidentiality of local/server evidence	Envelope/object/session design; central access policy
Trusted time	Ordering, expiry and custody context	Authenticated source plus quality/offset evidence

11.1. Certificate/key lifecycle



11.2. Revocation checking

- Online checks use authoritative certificate and registry state through OCSP/CRL or equivalent.
- Offline checks use cached signed freshness-bounded trust packages.
- Emergency revocation propagates to auth, policy, pairing, upload and admin services.
- Certificate validity, registry status and authorization are evaluated separately.

11.3. CA rotation

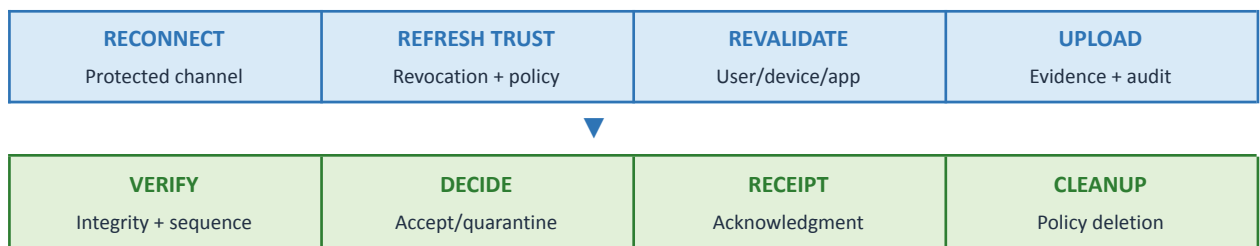
Support overlapping trust anchors, controlled fleet rollout, dual validation, rollback and adoption telemetry. Trust-anchor change is privileged and dual-controlled.

12. Offline Operations and Reconciliation

Offline capability is designed, not accidental. A signed entitlement defines user, device, APK instance/release, peripherals, allowed actions, policy version, issue/expiry and reconciliation obligations.

CONTROL	REQUIRED BEHAVIOR
Eligibility	Only previously online-authenticated compliant contexts
Lifetime	Short, risk-based and explicitly bounded
Permitted functions	Unlock, approved pairing, record and queue evidence
Prohibited functions	Tenant admin, reassignment, export/deletion and trust change
Local integrity	Protected keys, encrypted evidence, tamper-evident audit and sequencing
Expiry	Fail safely; preserve existing evidence and flag state
Reconnection	Revalidate identities/bindings; refresh trust; upload and reconcile
Conflict	Quarantine when revoked during offline window; never discard silently

12.1. Reconciliation sequence



12.2. Decisions to finalize

- Maximum offline entitlement by role/function
- Offline certificate-expiry behavior
- Grace period for ongoing recording
- Trusted-time and rollback/tamper detection
- Post-revocation quarantine/review process
- Storage exhaustion behavior

13. Revocation, Compromise and Recovery

KILL SWITCH	SCOPE	IMMEDIATE EFFECT
User disable	cmendez.aeriaone.com	Block/terminate sessions and dependent bindings
Device revoke	DEV-92A71C	Block device auth, APK use and peripheral control
Certificate revoke	Specific serial/key	Reject challenge/mTLS with affected credential
APK instance disable	APPINST-8F27A91C	Disable one installation
Release revoke	APK v3.4.1	Block all instances of release
Peripheral revoke	BWC-0042	Block pairing/operation/upload attribution
Entitlement removal	video.upload	Remove function without replacing identity
Session terminate	Specific jti/session	Immediate operational termination
Tenant suspend	QPD	Stop tenant operations under governance

13.1. Response pattern

1. **Detect/classify**: Identify affected trust subject and dependencies.
2. **Contain precisely**: Use narrowest effective kill switch; expand if uncertainty requires.
3. **Terminate active trust**: End sessions/bindings and block renewal/pairing/upload.
4. **Preserve evidence**: Retain logs, state, certificate/binding records and queued evidence.
5. **Recover trust**: Fresh keys/certs, re-enroll, return-to-service and re-bind.
6. **Review**: Confirm fleet impact, detection coverage and policy gaps.

FACTORY RESET

Reset must destroy/invalidate old local identity and APK instance. Trust returns only after controlled re-enrollment, posture validation, certificate issuance and return-to-service approval.

14. Audit, Monitoring and Administrative Control

EVENT FAMILY	MINIMUM EVENTS
Identity lifecycle	Create, approve, activate, suspend, recover, change role and offboard
Certificate/key	Generate, issue, renew, rotate, revoke, expire and trust change
Device/peripheral	Enroll, assign, posture, pair/bind/unbind, loss, wipe and retire
Application	Build approval, sign, release, install, activate, update, rollback and kill
Authentication/session	PIN failures, challenge, issue/renew/deny/terminate and offline entitlement
Authorization	Policy version, subject/resource/action, reason and enforcement result
Evidence	Capture, sign, encrypt, queue, upload, verify, accept, view/export/delete
Administration	Privileged login, policy/tenant change, emergency access and approval
Security	Rogue APK/device, revoked use, anomalous pairing/upload and tamper

14.1. Audit qualities

- Unique event ID/trusted timestamp
- Actor and workload identity
- Tenant, device, APK and session context
- Action, target and decision reason
- Previous/new lifecycle state
- Cross-service correlation IDs
- Tamper-evident retention
- SIEM export without log manipulation

14.2. Separation of duties

ROLE	PRIMARY AUTHORITY	KEY RESTRICTION
Police Officer	Record, pair, upload and authorized view	No deletion, tenant admin or override
Supervisor	Team review and defined exception approval	No PKI root/platform admin
Evidence Custodian	Retention, disclosure, export and custody	Cannot modify original/provenance
QPD Administrator	QPD users, roles, assets and assignments	No cross-tenant scope
AeriaOne Operator	Platform/trust-service operation	No routine evidence access
Auditor	Policy, audit and custody records	Read-only
Security Responder	Incident containment/revocation	Time-bound; post-action review

15. High-Level Security Requirements

ID	REQUIREMENT
IAM-01	Unique authoritative identity for every tenant, user, device, credential, release, APK instance, workload, session and evidence object.
IAM-02	QPD data, policy and administration isolated from other tenants.
IAM-03	Routine login retrieves bound username and uses PIN-authorized protected-key access.
IAM-04	Fresh challenge-response; PIN/private key never transmitted.
IAM-05	Purpose-separated, independently revocable user/device/app/evidence keys.
IAM-06	Binding Registry authoritative for relationships and lifecycle history.
IAM-07	Only approved releases and active bound APK instances reach production.
IAM-08	Authorization evaluates tenant, subject, devices, software, bindings, entitlement, resource, action and context.
IAM-09	Sessions short-lived, scoped, uniquely identified and terminable.
IAM-10	Peripherals retain independent identities and never impersonate users.
IAM-11	Evidence has verifiable provenance, integrity, encryption and custody.
IAM-12	Server acceptance precedes policy-controlled local deletion.
IAM-13	Offline authorization signed, bounded and reconciled.
IAM-14	Granular revocation across all trust subjects.
IAM-15	Revocation preserves signing-time historical attribution.
IAM-16	Security/admin/authorization/evidence events centrally correlated and tamper-evident.
IAM-17	Backend workloads use distinct least-privilege identities.
IAM-18	Reset/repair requires re-enrollment and return-to-service.
IAM-19	CA rotation supports controlled overlap and fleet migration.
IAM-20	Baseline does not claim officer biometrics or formal MFA.

16. Implementation Roadmap and Ownership

PHASE	CAPABILITIES	EXIT CONDITION
1. Trust foundation	Tenant, registries, CA profiles, release signing, HSM/KMS and audit	Independent identities enroll, prove keys and revoke
2. Binding & session	Trust graph, challenge-response, policy, tokens and admin controls	User-device-APK trust evaluated before functions
3. Peripheral operations	Enrollment, pairing, binding, firmware policy and loss workflows	Peripherals act as themselves for validated session
4. Evidence trust	Provenance, signing, encryption, resumable ingest, receipt and custody	Evidence verifiable from capture through access
5. Offline & resilience	Offline entitlement, reconciliation, CA/key rotation, reset/return	Field operations survive disruption safely
6. Operational assurance	SIEM, alerts, drills, recovery, SLOs and reviews	Control effectiveness and recovery demonstrated

16.1. Responsibility boundary

AREA	QPD	AERIAONE
Users/roles	Personnel decisions and approvals	Enforcement workflow and audit
Devices	Custody, assignment and incident reporting	Enrollment, certificates, registry and trust actions
APK	Approve rollout window	Build, test, sign, distribute and revoke
Evidence	Ownership, case access, retention/disclosure	Integrity, encryption, custody platform
Incidents	Local reporting/containment decisions	Technical containment, telemetry and recovery
PKI/keys	Governance as agreed	Operate/integrate CA/HSM/KMS
Audit/SIEM	Monitor/investigate QPD events	Generate, retain and export telemetry

16.2. Required next design artifacts

- Registry/binding logical data model
- Certificate profiles and key standard
- API/token claim specification
- Role-entitlement-resource matrix
- Priority workflow sequence diagrams
- Evidence manifest and acceptance receipt schema
- Offline entitlement/quarantine policy
- Threat model across endpoints, backend, PKI and supply chain
- Audit catalogue, alerts and revocation SLOs
- QPD/AeriaOne RACI and runbooks

Appendix A. Workflow Coverage Catalogue

This catalogue provides lifecycle completeness and traceability; roadmap phasing and risk determine implementation sequence.

A.1. Tenant & Governance

#	WORKFLOW	HIGH-LEVEL PURPOSE
1	Tenant / Organization Onboarding	Create QPD tenant, CA trust, policies, roles and admins
59	Role / Entitlement Change	Change permissions without replacing identity certificate
68	Tenant Transfer / Organizational Reassignment	Move asset/person between units under policy

A.2. User Identity

#	WORKFLOW	HIGH-LEVEL PURPOSE
2	User Enrollment	Create cmendez.aeriaone.com; assign QPD, role and entitlements
3	User Certificate Issuance	Generate protected key/CSR; issue and bind certificate
4	User PIN / Password Setup	Establish local secret authorizing use of the user key
5	User PIN / Password Change	Change the local secret under policy
6	Forgotten PIN / Password Recovery	Controlled recovery/re-enrollment without weakening trust
7	User Certificate Renewal	Replace expiring certificate while retaining identity
8	User Certificate Revocation	Invalidate compromised/terminated credential
9	User Suspension / Reactivation	Temporarily change backend authorization state
10	User Offboarding	Revoke credentials, sessions, bindings and entitlements

A.3. Device Trust

#	WORKFLOW	HIGH-LEVEL PURPOSE
11	Device Manufacturing Enrollment	Establish immutable device identity and certificate
12	Android Mobile Device Enrollment	Register handset, assess hardware and issue identity
13	Body Camera Enrollment	Establish independent BWC identity and certificate
14	Smart Goggles Enrollment	Establish independent goggles identity and certificate
15	Device Certificate Renewal	Rotate expiring device certificates
16	Device Certificate Revocation	Revoke compromised, lost or retired device
17	Device Reassignment	Move device between authorized officers or units
18	Device Replacement	Replace failed device while preserving continuity
19	Lost / Stolen Device	Revoke trust, terminate bindings, quarantine/optionally wipe
20	Device Decommissioning	Revoke certificate, destroy keys, wipe and retire
66	Factory Reset / Re-enrollment	Prevent reset device retaining previous identity
67	Return-to-Service	Revalidate repaired/recovered device before trust restoration

A.4. Application Trust

#	WORKFLOW	HIGH-LEVEL PURPOSE
21	APK Build & Release	CI/CD, scan, approve and production-sign release
22	APK Initial Installation	Controlled distribution and installation
23	APK Activation / User Binding	Validate APK, device, user, tenant and entitlement
24	APK Update	Authenticate and install an approved version
25	APK Rollback Prevention	Block vulnerable or unauthorized versions
26	APK Revocation / Kill	Block compromised/deprecated release or instance

A.5. Authentication & Session

#	WORKFLOW	HIGH-LEVEL PURPOSE
27	User Login / Unlock	PIN authorizes use of the provisioned user identity
28	Session Establishment	Validate user, device, APK, tenant, bindings and authorization
29	Session Renewal	Refresh short-lived authorization safely
30	Logout / Session Termination	Terminate session and temporary bindings

A.6. Pairing & Binding

#	WORKFLOW	HIGH-LEVEL PURPOSE
31	Android to Body Camera Pairing	Mutually authenticate devices and establish secure relationship
32	Android to Goggles Pairing	Mutually authenticate handset and smart goggles
33	Officer to Peripheral Binding	Associate peripheral operation with cmendez.aeriaone.com
34	Peripheral Unbinding	End binding on shift end, logout, timeout or revocation

A.7. Evidence Trust

#	WORKFLOW	HIGH-LEVEL PURPOSE
35	Recording Start Authorization	Establish authenticated context before capture
36	Evidence Creation	Create media and provenance metadata
37	Evidence Signing	Sign artifact hash and provenance
38	Evidence Encryption	Encrypt artifact under evidence policy
39	Evidence Local Storage	Protect evidence pending upload
40	Evidence Upload / Ingest	Authenticate context and transfer securely
41	Upload Integrity Verification	Verify hash, signatures, certificates and metadata
42	Evidence Provenance / Chain of Custody	Record creation, transfer, access and custody
43	Interrupted Upload / Resume	Resume without duplication or corruption
44	Evidence Server Acceptance	Formally validate and accept into evidence store
45	Local Evidence Deletion	Delete only after verified acceptance and policy approval
46	Evidence Access / Playback	Authenticate and authorize viewing
47	Evidence Export / Sharing	Controlled export with custody and audit context

#	WORKFLOW	HIGH-LEVEL PURPOSE
48	Evidence Retention / Archival	Apply tenant/legal retention
49	Evidence Secure Deletion	Authorized destruction after retention expiry

A.8. Offline & Resilience

#	WORKFLOW	HIGH-LEVEL PURPOSE
50	Offline Authentication	Permit defined functions using cached signed authorization
51	Offline Recording	Continue evidence creation under cached policy
52	Offline to Online Reconciliation	Revalidate identities/bindings and synchronize

A.9. PKI & Key Lifecycle

#	WORKFLOW	HIGH-LEVEL PURPOSE
53	Certificate Expiry Handling	Define safe behavior for offline expiry
54	Key Rotation	Replace keys independently of identity
55	Key Compromise Recovery	Revoke affected trust and establish fresh keys
56	CA / Intermediate CA Rotation	Rotate trust infrastructure without breaking fleet

A.10. Platform Operations

#	WORKFLOW	HIGH-LEVEL PURPOSE
57	Backend Service Identity	Authenticate APIs and platform workloads
58	Admin Authentication	Strongly authenticate QPD/AeriaOne administrators
64	Time Synchronization / Trusted Timestamping	Provide reliable time for media, signatures and custody
65	Backend Trust / Policy Update	Distribute trust anchors, revocation and policy

A.11. Incident & Revocation

#	WORKFLOW	HIGH-LEVEL PURPOSE
60	Emergency Access Revocation	Immediately kill user/device/app/session access
63	Compromise / Incident Response	Contain affected user/device/application/key

A.12. Audit & Monitoring

#	WORKFLOW	HIGH-LEVEL PURPOSE
61	Audit Event Generation	Record security-relevant lifecycle activity
62	Security Alerting	Detect failures, revoked identities and rogue software/devices

Appendix B. Acceptance Checklist

- QPD tenant isolation and named administrators verified.
- cmendez.aeriaone.com has immutable ID, role/status and entitlements.

- Routine login displays enrolled identity and challenges only PIN/passcode.
- PIN authorizes local key use; backend receives no PIN/private key.
- User/device challenge-response uses fresh nonce and rejects replay.
- Android/BWC/goggles credentials are unique and independently revocable.
- APK release trust and instance activation/binding checked separately.
- Copied APKs, emulators and unregistered devices cannot create production sessions.
- Bindings include state, source/approval, policy version, times and audit.
- Tokens are short-lived and scoped to the full validated context.
- Peripherals sign as devices and user attribution comes through binding/session.
- Evidence carries provenance, integrity, encryption and custody.
- Authoritative server acceptance precedes local deletion.
- Offline entitlements expire, constrain functions and reconcile.
- Granular kill switches operate across trust subjects.
- Revocation preserves historical validation evidence.
- Reset/repair requires re-enrollment/return-to-service.
- Events are correlated, tamper-evident and SIEM-exportable.
- Key purposes are separated and rotated under control.
- Implementation does not claim formal officer MFA/biometrics.

End of Document
